

[별표 2]

기술적·물리적·관리적 보안대책 마련 기준 (제9조 관련)

I. 목 적

이 기준은 제9조에서 정하는 통신사기정보 처리의 안전성 확보를 위한 기술적·물리적·관리적 대책의 구체적인 기준을 정함을 목적으로 한다.

II. 기술적·물리적·관리적 보안대책

1. 접근통제

- ① 정보공유분석기관은 통신사기정보를 처리하는 전산시스템(이하 "통신사기정보처리시스템"이라 한다)에 대한 접근권한을 전기통신금융사기 정보의 분석 및 제공 업무에 필요한 최소한의 인원에게만 부여한다.
- ② 정보공유분석기관은 전보 또는 퇴직 등 인사이동이 발생하여 통신사기정보를 처리하는 업무를 담당하는 자(이하 "통신사기정보취급자"라 한다)가 변경되었을 경우 지체 없이 통신사기정보처리시스템의 접근권한을 변경 또는 말소한다.
- ③ 정보공유분석기관은 제1항 및 제2항에 따른 권한 부여, 변경 또는 말소에 대한 내역을 기록하고, 그 기록을 최소 3년간 보관한다.
- ④ 정보공유분석기관은 통신사기정보처리시스템에 침입차단시스템과 침입탐지시스템을 설치하여 보호한다.
- ⑤ 정보공유분석기관은 통신사기정보취급자가 추측하기 쉬운 단어나 숫자를 비밀번호로 이용하지 않도록 비밀번호 작성규칙을 수립하고 이행한다.
- ⑥ 정보공유분석기관은 취급 중인 통신사기정보가 권한이 없는 제3자가 접근할 수 없도록 통신사기정보처리시스템 및 통신사기정보취급자의 정보처

리기기를 설정한다.

⑦ 정보공유분석기관은 통신사기정보처리시스템 관련 개발업무에 사용되는 업무장소 및 전산설비는 운영업무용과 분리하여 설치·운영한다.

⑧ 정보공유분석기관은 업무목적을 위하여 불가피한 경우에만 외부사용자에게 통신사기정보처리시스템에 대한 최소한의 접근권한을 부여하고, 권한 부여에 관한 기록을 3년 이상 보관하는 등 적절한 통제시스템을 갖추어야 한다.

2. 접속기록의 위·변조방지

① 정보공유분석기관은 통신사기정보취급자가 통신사기정보처리시스템에 접속하여 통신사기정보를 처리한 경우에는 처리일시, 처리내역 등 접속기록을 저장하고 이를 월 1회 이상 정기적으로 확인·감독한다.

② 정보공유분석기관은 통신사기정보처리시스템의 접속기록을 1년 이상 저장하고, 위·변조되지 않도록 별도 저장장치에 백업 보관한다.

3. 통신사기정보의 암호화 처리 및 외부망 분리

① 정보공유분석기관은 사기정보제공기관 및 사기정보이용기관과 전용회선(전용회선과 동등한 보안수준을 갖춘 가상의 전용회선을 포함한다)으로 통신사기정보를 송·수신하여야 하며, 보안서버 구축 등의 조치를 통해 통신사기정보를 암호화하여야 한다. 보안서버는 다음 각 호의 어느 하나의 기능을 갖추어야 한다.

1. 웹서버에 SSL(Secure Socket Layer) 인증서를 설치하여 통신사기정보를 암호화하여 송·수신하는 기능
2. 웹서버에 암호화 응용프로그램을 설치하여 통신사기정보를 암호화하여 송·수신하는 기능

② 정보공유분석기관은 통신사기정보를 PC에 저장할 때에는 이를 암호화해야 한다.

③ 정보공유분석기관은 다음 각 호의 기준에 따라 개인식별정보의 암호화 등의 조치를 취하여야 한다.

1. 정보통신망을 통하여 송수신하거나 보조저장매체를 통하여 전달하는 경우에는 암호화하여야 한다.
2. 인터넷 구간 및 인터넷 구간과 내부망의 중간 지점(DMZ : Demilitarized Zone)에 저장할 때에는 암호화하여야 한다.
3. 정보공유분석기관이 내부망에 개인식별정보를 저장하는 경우에는 암호화하여야 한다.
4. 업무용 컴퓨터에 저장하여 관리하는 경우에는 상용 암호화 소프트웨어 또는 안전한 알고리즘을 사용하여 암호화하여야 한다.

4. 컴퓨터바이러스 방지

- ① 정보공유분석기관은 통신사기정보처리시스템 및 통신사기정보취급자의 정보처리기기에 컴퓨터바이러스, 스파이웨어 등 악성프로그램의 침투 여부를 항시 점검·치료할 수 있도록 백신소프트웨어를 설치하여야 한다.
- ② 제1항에 따른 백신 소프트웨어는 월 1회 이상 주기적으로 갱신·점검하고, 바이러스 정보가 발령된 경우 및 백신 소프트웨어 제작 업체에서 업데이트 공지를 한 경우에는 즉시 최신 소프트웨어로 갱신·점검하여야 한다.

5. 출력·복사시 보호조치

- ① 정보공유분석기관은 통신사기정보처리시스템에서 통신사기정보의 출력시(인쇄, 화면표시, 파일생성 등) 용도를 특정하여야 하며, 용도에 따라 출력항목을 최소화 한다.

② 정보공유분석기관은 통신사기정보를 조회하는 경우 조회자의 신원, 조회 일시, 대상정보, 목적, 용도 등의 기록을 관리하여야 하며, 영 제10조의4제14항에 따른 운영기준에 따라 사기정보이용기관에 통신사기정보를 제공하는 경우 이외의 경우로서 통신사기정보취급자가 통신사기정보를 보조저장매체에 저장하거나 이메일 등의 방법으로 외부에 전송하는 경우에는 관리책임자의 사전 승인을 받아야 한다.

③ 통신사기정보취급자는 제1항 및 제2항의 준수에 필요한 내부시스템을 구축하여야 하며 사전 승인시 승인신청자에게 관련 법령을 준수하여야 한다는 사실을 주지시켜야 한다.

6. 통신사기정보보호최고책임자 지정

① 정보공유분석기관은 다음 각 호의 업무를 담당하는 통신사기정보보호책임자를 지정하여야 한다. 이 경우 통신사기정보보호최고책임자는 임원인 자로 지정하여야 하며, 「개인정보 보호법」 또는 「전자금융거래법」에 따른 정보보호최고책임자, 「신용정보의 이용 및 보호에 관한 법률」에 따른 신용정보관리·보호인을 겸임할 수 있다.

1. 통신사기정보의 관리 및 보호 계획의 수립 및 시행
2. 통신사기정보의 관리 및 보호 실태, 관련 법령 및 규정 준수 여부에 대한 점검 및 개선
3. 통신사기정보 유출 등을 방지하기 위한 내부통제시스템의 구축 및 운영
4. 통신사기정보취급자에 대한 관리·감독 및 교육
5. 통신사기정보 처리업무를 위탁하는 경우 수탁자의 관리 및 감독
6. 통신사기정보 열람 및 정정청구 등 정보주체의 권리행사 및 피해구제

7. 통신사기정보 유출시 대응 계획의 수립 및 시행

- ② 통신사기정보보호책임자는 제1항의 업무처리에 따른 기록을 3년간 보존하며, 점검결과를 최고경영자에 보고하고 업무처리절차에 적절히 반영하여야 한다.

7. 제재기준 마련

정보공유분석기관은 통신사기정보의 유출 및 오·남용에 대한 자체 제재기준을 마련하여야 한다.